

HPS CUSTOM PRINT & DESIGN

PROJECT STATUS & NEXT BUILD REPORT

REPORT 3
30 SEP 2026

Full-project implementation
and readiness audit

Purpose and assessment basis

This third report audits the repository end to end: storefront and Design Studio, customer actions, Node API, local and PostgreSQL persistence paths, migrations, seed data, setup documentation, and the earlier implementation/status reports. It updates Report 2 with the same weighted capability method and separates prototype scope completion from production readiness.

38%	12%	0
Estimated roadmap complete	Estimated launch readiness	First-party automated test files

Executive assessment

HPS is a substantial storefront prototype, not a production-ready commerce service. Customers can browse five products, edit product-specific front/back mockups, save designs locally or to an account, see estimated prices, keep a browser cart, request server quotes and submit validated orders. Authentication, address-book, design-version, JSON fallback, PostgreSQL repository, migration and seed foundations are present.

Production gates remain: live PostgreSQL verification, real payment processing, staff/admin operations, print-ready asset handoff, order-to-design linkage, first-party automated tests, hardened origin/session policies and deployment. The audit found a tracked development user-data file containing account-identifying data and a password hash; this report intentionally excludes the actual values.

Decision
Keep the current build in local/demo use. Resolve data hygiene and origin/session policy, then make isolated PostgreSQL staging validation the first engineering gate.

The 38% figure is weighted engineering scope completed, not elapsed time or a guarantee. It updates Report 2's approximately 36%.

1. Completion estimate and scoring method

Weights are retained from Report 2 for directional comparison. Partial credit is given for implemented code; unverified production behavior is not counted as complete. Weighted contributions total 38.44%, rounded to 38%.

Capability area	Weight	Build status	Points
Brand, UX and storefront shell	12%	85%	10.20
Catalog and product discovery	8%	70%	5.60
Design Studio and account sync	12%	72%	8.64
Cart and checkout	12%	35%	4.20
Identity, designs and addresses	8%	60%	4.80
Backend and PostgreSQL	20%	18%	3.60
Payments, admin, production and delivery	18%	5%	0.90
Security, QA and deployment	10%	5%	0.50
TOTAL	100%	38.44%	38.44

Comparison with Report 2

Report 2 estimated 35.5%, rounded to 36%, on 29 September. This reassessment gives more credit to the product-specific mockups and front/back interaction, updated catalog presentation and visual/accessibility refinement. Backend, checkout, payment, production and deployment scores remain constrained because their release gates were not verified. The three-point movement is a directional reassessment, not measured velocity.

Production readiness is separately estimated at about 12%: there is no verified PostgreSQL connection, no live payment integration, no operational admin/production workflow, no first-party automated test suite and unresolved data/origin/session concerns.

Evidence confidence

High: repository inventory, API paths, catalog, SQL model, test-script absence, dependency audit and read-only API smoke tests. Medium: manual browser interactions and mockup/canvas behavior. Unverified: live PostgreSQL, payment/fulfillment, concurrency, deployment, and external providers.

2. Storefront sections and customer actions

index.html is a single-file prototype containing markup, styles, SVG generation, Fabric.js editing, browser persistence and direct API calls.

Section	Implemented actions and current behavior
Header/navigation	Brand link; Shop, Design Studio and How it works anchors; mobile menu; cart open/close and count.
Hero/service proof	Start designing and Explore products links; brand proposition; T-shirt hero mockup; three service steps.
Customer account	Email/password registration and sign-in, signed-in state, order history and sign-out. Password reset and email verification are absent.
Shop/product details	Five products; Men/Women/Unisex toggle; search; Apparel/Accessories and price filters; product details and Customize action.
Design Studio	T-shirt, hoodie, denim, bag and cap SVGs; front/back; colors; apparel sizes and accessory One size; image upload, text, duplicate/delete, emoji templates, color/opacity; local/account save/load; quality guidance; PNG export.
Cart/checkout drawer	Persistent local cart, quantity/remove, provisional/server totals, saved address selection, Bangladesh phone/address validation, COD/bKash/Nagad/Card selector and order submission.
How it works/footer	Static lifecycle explanation from order to delivery; not a live order tracker.

Prototype limitation
Mockups are shaded SVG illustrations, not photography or garment-accurate 3D. The template set is small; advanced layers, full template catalogue, manufacturing export formats and calibrated physical print dimensions remain future scope.

Browser review verified all five products, front/back switching, accessory sizing, cart toggling, mobile navigation/overflow and PNG export. It was a manual smoke review, not a cross-browser automated suite.

3. API surface and end-to-end connections

Group	Routes present	Limitations
Health/catalog/quote	GET /api/health; GET /api/products; POST /api/cart/quote	Health reports JSON-development without DATABASE_URL. Catalog and quote read products.json even in PostgreSQL mode.
Authentication	POST /api/auth/register, /login, /logout; GET /api/auth/me	Script password hashes and session cookie. JSON sessions are in-memory. No rate limiting, reset or verification.
Orders	POST /api/orders; GET /api/orders	Server recalculates prices and stores order. No staff order management or status-transition API.
Saved designs	GET/POST /api/designs; GET /api/designs/:id; POST /api/designs/:id/versions	Authenticated create/list/read/version append; no delete/rename endpoint; order does not bind artwork version.
Saved addresses	GET/POST /api/addresses; PUT/DELETE /api/addresses/:id	Authenticated ownership-scoped address CRUD.
Not present	Payment gateway/webhook, staff/admin, production, shipment, review, notification, analytics routes	Related schema does not provide operational workflows.

Read-only API smoke checks

A temporary local API was started in JSON-development mode and stopped after checks. Health returned ok/json-development; the catalog returned five items. A valid mixed hoodie/bag quote returned BDT 2,050 including delivery; an invalid bag size was rejected. No records were created by those checks.

Integration findings

- Checkout POST omits credentials: include. From file:// origin an authenticated order can be stored as a guest order.
- Payment labels are not real transactions; no provider flow, verified webhook, reconciliation or refunds exist.
- PostgreSQL order items do not set product_variant_id or design_version_id; production cannot reliably locate the exact artwork version.
- Frontend API URL is hardcoded to 127.0.0.1:3000; no deployable frontend/API configuration was found.

4. Data model, persistence and project structure

PostgreSQL repositories are selected when DATABASE_URL exists; otherwise the API uses JSON files. Only JSON-development mode was available for this audit. Pool/migration/query code is not evidence of a live database integration.

Migration coverage

The initial schema covers users, categories, products, variants, print areas, designs/versions, carts/items, addresses, orders/items, payments, production jobs, shipments, reviews, notifications and audit logs. A second migration adds hashed auth_sessions. Constraints cover foreign keys, status sets, variant uniqueness, quantities and nonnegative amounts.

Persistence and consistency

- products.json is the API quote/catalog authority and seed source; PostgreSQL catalog edits do not govern quotes.
- Tracked development user/order JSON files are not safe production storage. The user file has account-identifying information and a password hash; values omitted. Generated designs/addresses JSON files are ignored.
- JSON fallback has no transactional consistency or multi-process safety. Do not use it as production persistence.
- Cart, print profiles, payments, production, shipment, reviews, notifications and audit tables have little/no API behavior.
- Server listens on loopback. Direct file opening requires deliberate development CORS; production needs trusted hosting and same-origin/origin policy.

Repository map

Path	Purpose
index.html	Monolithic storefront, editor, cart, checkout, account and API client.
server/index.js	HTTP routing, validation, JSON fallback and quote/order behavior.
server/repositories.js; server/db.js	Parameterized PostgreSQL operations, transactions and connection pool.
server/migrate.js; database/*.sql	Migration runner and commerce/auth schema.
server/seed.js; data/products.json	Catalog and variant seeding; JSON source catalog.
README.md; package.json; database/README.md	Run/setup instructions, scripts and roadmap.

5. Audit findings and release blockers

Priorities indicate the order to address issues before real-customer use. Findings are based on code/configuration inspection; no claim is made that every potential defect was tested.

Priority	Finding	Action
P0 Privacy	Tracked data/users.json contains account-identifying data and a script password hash. Values intentionally omitted.	Remove user data from tracked fixtures/history as appropriate; ignore user/order stores; replace with synthetic fixtures; rotate any real/reused credentials.
P0 Origin/session	API allows origin null with credentialed requests; session cookie lacks Secure. Development settings are not a production policy.	Use same-origin or strict allowlist, HTTPS Secure cookie, CSRF protection, session cleanup and login rate limiting.
P0 Fulfillment	Order item rows do not bind variant/design_version IDs or production assets.	Persist exact variant and immutable design-version references; durable print-ready storage and operator retrieval.
P0 Payments	bKash/Nagad/Card selectable but no gateway, verified callback or reconciliation.	Disable online options until integrated; then sandbox signatures, amount match, replay/idempotency and refund flow.
P1 Database	No live DATABASE_URL/DB integration test was available.	Stage PostgreSQL; run migrations twice, seed, ownership/CRUD/concurrency/rollback tests; verify readiness.
P1 Checkout identity	Order fetch omits credentials: include.	Serve same-origin or credentialed allowed origin; test authenticated order history.
P1 QA/deployment	No first-party automated tests, npm test, CI or deployment manifests found.	Add API/browser tests, CI, environment validation, hosting, secret management, backups, telemetry and rollback.
P2 Feature depth	No recovery/verification; JSON sessions reset on restart; product/pricing rules not admin-configurable.	Keep demo-only; complete identity lifecycle and centralized product/price operations.

Dependency audit: npm audit --omit=dev returned zero known production-dependency advisories at the time checked. This is not an application security assessment.

6. Prioritized next-build roadmap

Order	Milestone	Acceptance criteria
1 Immediate	Data hygiene and safe origin/session baseline.	No personal records/hashes in tracked fixtures; rotate relevant credentials; explicit origin policy; production Secure/HttpOnly/SameSite cookie; CSRF, rate limits, no internal error leakage.
2 P0	Connect isolated PostgreSQL staging.	Health reports connected; migrations repeat safely; idempotent seed; CRUD and ownership; design-version concurrency and order rollback tests.
3 P0	Make database catalog/pricing authoritative.	DB controls products, active flags, colors/sizes and quote prices; invalid variants reject; one shared rule source.
4 P0	Link design, cart, order and production.	Each order line stores exact variant and immutable artwork version; validated print dimensions; durable file export and production retrieval.
5 P1	Payment provider and idempotent checkout.	One provider sandbox, signed webhook, replay protection, amount reconciliation, paid state only after confirmation, COD path.
6 P1	Admin and delivery operations.	Role-protected review/approval/status changes, production checklist, shipment tracking and customer-visible order state.
7 P1	Automated quality and release.	CI unit/API/UI tests, browser/mobile/accessibility checks, TLS, managed secrets, backups, monitoring and rollback.

Release gate

Do not accept real orders or use live payment credentials until items 1-4 pass in staging. Keep online-payment options unavailable or clearly marked as not active until item 5 passes.

7. Verification performed and run notes

Check	Result	Boundary
Repository audit	Reviewed storefront, server, repository code, migrations, seed, README, package and previous reports.	Static review.
Browser smoke	Products/sides, accessory size, cart, mobile navigation/overflow and PNG export verified.	Manual, not cross-browser.
Mockup geometry	Print guide aligned and garments framed on six tee/hoodie/denim views.	Illustrative SVG only.
API smoke	Health and catalog pass in JSON mode; valid mixed quote BDT 2,050; invalid size rejected.	No DB or order writes.
Syntax/whitespace	Inline JS parsed with Node; git diff --check passed.	No build/lint script.
Dependency audit	npm audit --omit=dev: zero known advisories.	Point-in-time dependency check.
Automated tests	No first-party test files or npm test script found.	Low regression confidence.

Run locally

Demo storefront: open index.html in a modern browser; Fabric.js is loaded from a CDN. API: npm start, default http://127.0.0.1:3000. Check GET /api/health and GET /api/products. Without DATABASE_URL, storage is JSON-development. For PostgreSQL, configure a private .env from .env.example, run npm install, npm run db:migrate, npm run db:seed, then npm start. Never commit real credentials or customer records.

Conclusion

The existing prototype is valuable for customer-flow demonstrations. The next meaningful progress is not more mockup polish alone: it is a tested chain from authoritative product/variant data to saved artwork version, verified payment, operator production handoff and monitored deployment.

Current estimate

End-to-end roadmap: 38% complete (Report 2: approximately 36%). Production launch readiness: approximately 12%. Key remaining areas: account-data hygiene, strict origin/session policy, PostgreSQL validation, design/order linkage, payments, operations, automated QA and deployment.